

Cybersecurity Portfolio

Control Categories

By: giuseppeTaquiri

Control Categories

Controls within cybersecurity are grouped into three main categories:

- Administrative/Managerial controls
- Technical controls
- Physical controls

Administrative/Managerial controls address the human component of cybersecurity. These controls include policies and procedures that define how an organization manages data and clearly define employee responsibilities, including their role in protecting the organization. While administrative controls are typically policy-based, the enforcement of those policies may require the use of technical or physical controls.

Technical controls consist of solutions such as firewalls, intrusion detection systems (IDS), intrusion prevention systems (IPS), antivirus (AV) products, encryption, and more. Technical controls can be used in a number of ways to meet organizational goals and objectives.

Physical controls include door locks, cabinet locks, surveillance cameras, badge readers, and similar protections. They are used to limit physical access to assets by unauthorized personnel.

Control Types

Control types include:

- Preventative
- Corrective
- Detective
- Deterrent

These controls work together to provide defense in depth and protect assets. Preventative controls are designed to prevent an incident from occurring. Corrective controls restore systems after incidents. Detective controls determine whether an incident has occurred or is in progress. Deterrent controls discourage attacks.

Administrative Controls

Control Name	Control Type	Control Purpose
Least Privilege	Preventative	Reduce risk and overall impact of malicious insider or compromised accounts
Disaster recovery plans	Corrective	Provide business continuity
Password policies	Preventative	Reduce likelihood of account compromise through brute force or dictionary attack techniques
Access control policies	Preventative	Bolster confidentiality and integrity by defining which groups can access or modify data
Account management policies	Preventative	Manage account lifecycle, reduce attack surface, and limit impact from former employees and default accounts
Separation of duties	Preventative	Reduce risk and impact of malicious insiders or compromised accounts

Technical Controls

Control Name	Control Type	Control Purpose
Firewall	Preventative	Filter unwanted or malicious traffic from entering the network
IDS/IPS	Detective	Detect and prevent anomalous traffic matching a signature or rule
Encryption	Deterrent	Provide confidentiality to sensitive information
Backups	Corrective	Restore or recover systems after an event
Password management	Preventative	Reduce password fatigue
Antivirus (AV) software	Corrective	Detect and quarantine known threats
Manual monitoring, maintenance, and intervention	Preventative	Identify and manage threats, risks, or vulnerabilities in outdated systems

Physical Controls

Control Name	Control Type	Control Purpose
Time-controlled safe	Deterrent	Reduce attack surface and impact from physical threats
Adequate lighting	Deterrent	Deter threats by limiting hiding places
Closed-circuit television (CCTV)	Preventative/Detective	Reduce risk of incidents and provide evidence after events
Locking cabinets (for network gear)	Preventative	Prevent unauthorized access or modification of network infrastructure

Signage indicating alarm service provider	Deterrent	Deter attacks by reducing perceived likelihood of success
Locks	Deterrent/Preventative	Prevent unauthorized personnel from physically accessing assets
Fire detection and prevention systems	Detective/Preventative	Detect fire and prevent damage to physical assets such as servers and inventory